

Análise Forense de Memória

*Estudo Comparativo de Artefactos em Memória Volátil:
Infostealer (RedLine) vs. Ransomware (LockBit 4.0)*

Autor: David Miranda

Unidade: Análise Forense Digital, CTeSP em Cibersegurança

Lisboa, agosto de 2026

1 Sumário Executivo

Análise forense à memória volátil de dois sistemas comprometidos, comparando duas ameaças de natureza tática oposta: um infostealer (RedLine), orientado para a furtividade, e um ransomware (LockBit 4.0), desenhado para a extorsão.
Tese central: a pegada forense de uma ameaça não depende apenas da sua família, mas fundamentalmente da relação entre o ciclo de vida do processo e o instante exato da aquisição da memória.

2 amostras reais

RedLine Stealer (MaaS, 2020+) e LockBit 4.0, via MalwareBazaar

Caso A: captura ativa

processo RedLine ainda em execução

Caso B: captura póstuma

processo LockBit já terminado (cifra-e-sai)

NIST SP 800-86

+ ISO/IEC 27037:2012, cadeia de custódia com SHA-256/MD5

2 Ambiente Laboratorial e Critérios

- VMware Workstation Pro 17: VM vítima (Windows 10 22H2, 4 GB RAM) e VM de análise (Kali Linux, Volatility 3), ligadas por rede host-only sem acesso à Internet.
- Isolamento confirmado antes de cada detonação (ICMP externo falha, host-only responde); snapshot limpo revertido no fim.
- Disciplina de atribuição em três planos: Facto (provado pela imagem), Indício (sugerido, não provado) e Capacidade (o que o código sabe fazer, sem prova de execução).

A separação entre facto, indício e capacidade evita o erro mais comum em análise de memória: promover a comportamento observado o que é apenas conhecido da literatura sobre a família.

WinPmem 4.0.1

aquisição RAW; Volatility 3 v2.28.0 no Kali (via pipx)

Sysinternals

Process Explorer, TCPView, Autoruns, corroboração ao vivo

certutil / sha256sum

hash na origem e no destino, cadeia de custódia (Bag & Tag)

3

Caso A, RedLine: Aquisição da Memória

- Amostra detonada com o processo ativo; Defender desligado deliberadamente para permitir a execução.
- FTK Imager falhou (Could not start driver); WinPmem capturou com sucesso após ativar o test signing.
- Primeira imagem, em modo PTE Remapping, resultou não analisável pelo Volatility 3, sem símbolos do kernel casados.

Contribuição metodológica: o problema não era falta de conteúdo, mas o deslocamento físico da assinatura do kernel. Repetir a aquisição forçando o modo PhysicalMemory resolveu, produzindo uma imagem RAW linear plenamente analisável. Recomendação prática para sistemas de 64 bits com o Volatility 3.

5 GB

imagem RAW, espaço físico endereçável total da VM

PID 1040

malware.exe, Wow64 True (32 bits), criado 19:36:23 UTC

4 Caso A, RedLine: Resultados

- Genealogia explorer.exe → powershell.exe → malware.exe; presente no pslist e no psscan, sem ocultação.
- windows.malfind: 4 regiões PAGE_EXECUTE_READWRITE privadas, sem ficheiro mapeado, assinatura clássica de injeção de código (T1055).
- windows.netscan: 2 sockets TCPv4 CLOSED, posteriores à detonação; tentativa de C2 sem destino determinável (ambiente isolado).
- Sem serviços, sem entradas de arranque automático e sem handles a repositórios de credenciais: comportamento coerente com recolha rápida.

5 Caso A, RedLine: Atribuição e Cronologia

- Binário extraído da memória (SHA-256 próprio) cruzado com a ficha pública: assinatura RedLineStealer, 16 detecções de fornecedores, 16 regras YARA.
- Cadeias de texto no binário confirmam capacidade de recolha (Chrome, carteiras, geolocalização IP), sem prova de exfiltração efetiva.
- Cronologia reconstruída por CreateTime: arranque do sistema, sessão do utilizador, detonação, tentativas de rede, captura, tudo em menos de 5 minutos.

Diamond Model e Malware Behavior Catalog aplicados como leituras complementares: confirmam Execution e Defense Evasion como facto; Credential Access e Discovery ficam ao nível de capacidade, não de execução provada.

6 Caso B, LockBit: Aquisição da Memória

- Após a detonação, o ransomware cifrou os ficheiros do sistema com extensão hexadecimal única e depositou a nota Restore-My-Files.txt.
- WinPmem e FTK Imager falharam pela mesma causa: Driver Signature Enforcement recusou os controladores não assinados WHQL.
- A própria imagem ISO do FTK acabou cifrada pelo ransomware antes de ser usada.

Contribuição metodológica: recorrido ao Magnet DumpIt, cujo controlador é assinado, transferido por servidor HTTP sobre a rede host-only. Aquisição concluída com sucesso, 5 368 709 120 bytes, sem expor a máquina anfitriã nem ligar a vítima à Internet.

LockBitGreen4.0-rc-577

61 952 bytes, via MalwareBazaar

Processo já terminado

cifra-e-sai, sem persistência, no momento da captura

7 Caso B, LockBit: Resultados

- windows.psscan não revela qualquer processo do LockBit: confirma, a partir do dump, o comportamento de cifra-e-sai.
- windows.filescan recupera a nota de resgate e a própria amostra cifrada (extensão .c9478dabb503): prova de que a cifra alcançou o próprio dropper.
- windows.malfind só encontra regiões RWX de processos legítimos (Defender, SearchApp, motor .NET), sem injeção atribuível ao ransomware.
- Eliminação das cópias de sombra confirmada no sistema vivo (vssadmin sem itens); o comando concreto não ficou capturado na memória.

8 Caso B, LockBit: Atribuição em Memória

- Sem plugin YARA disponível no Volatility 3 2.28.0: varredura de cadeias de texto sobre a imagem física, usando os identificadores da nota de resgate como âncoras.
- Versão, identificador pessoal e chave de acesso recuperados diretamente da memória física, coincidentes com a nota lida no sistema vivo.

Atribuição mais robusta do que no Caso A: assenta na evidência principal (memória física), não apenas em fonte externa (ficha pública), porque o alvo já não tem regiões de processo ativas.

Rede: sem ligação

netscan só revela serviços legítimos, sem tráfego .onion

Persistência: ausente

977 mutexes e 1541 serviços, nenhum atribuível ao LockBit

9 Furtividade contra Destruição

O eixo central da comparação não é a família do malware, mas o momento da aquisição face ao ciclo de vida do processo. Perante o RedLine, basta ler a presença dos artefactos. Perante o LockBit, o analista tem de interpretar também a ausência.

Injeção de código (T1055)

RedLine: 4 regiões RWX

LockBit: ausente

Rasto em ficheiros

RedLine: mínimo

LockBit: massivo (cifra)

Classificação RNCSIRT

RedLine: Seg. Informação

LockBit: Disponibilidade

RedLine

processo vivo; injeção (T1055) e sockets residuais revelam a execução

LockBit

processo morto; filescan e strings revelam o impacto, não a execução

Lição central

interpretar a ausência é o que separa enumeração de análise forense

10 Classificação RNCSIRT (v3.3)

- Caso A, RedLine: primária Segurança da Informação (Exfiltração de Informação, tentada e não concretizada); secundária Código Malicioso (Sistema Infetado, injeção confirmada).
- Caso B, LockBit: primária Disponibilidade (Indisponibilização por ransomware, cifra provada); secundária Código Malicioso (Sistema Infetado, identificadores da campanha em memória).

A taxonomia classifica pela intenção do agente, não pela concretização. No Caso A a exfiltração foi tentada mas não concretizada, no Caso B a dupla extorsão anunciada na nota não chegou a materializar-se em rede: ambos os factos ficam registados, sem inflacionar a classificação primária.

11 Limitações

- Memory smear: um dump ao vivo não é um instantâneo perfeito, a aquisição sequencial pode gerar inconsistência parcial entre estruturas lidas em instantes diferentes.
- Sem baseline própria do sistema antes da detonação; mitigado pela captura ao vivo do estado limpo com Sysinternals.
- Âmbito exclusivo à memória: ficheiro de hibernação, paginação e artefactos em disco ficam fora do trabalho.
- Ambiente simulado e isolado; o valor está no método de aquisição e análise, não na representatividade de um incidente real.

12 Conclusão

01 A pegada depende do momento

Não é só a família do malware que determina o que se recupera, mas a relação entre o ciclo de vida do processo e o instante da captura.

02 Contribuições metodológicas reaproveitáveis

Modo PhysicalMemory em vez de PTE Remapping (Caso A); Magnet DumpIt como alternativa assinada quando o Driver Signature Enforcement bloqueia (Caso B).

03 Interpretar presença e ausência

As ferramentas de memória não bastam por si só, exigem sempre a interpretação humana para ler tanto o que está lá como o que, legitimamente, não está.

Obrigado. Perguntas?
